

AI spend governance, built for a health exchange.

Map every AI dollar to the work that drove it · forecast it · hold it to budget.

Outlay.ai

WHAT IT DOES

- **Attribute** — AI spend mapped to team, work type, ticket & engineer.
- **Forecast** — price planned work, back-tested on your own delivered work.
- **Govern** — per-program budgets, real-time pacing, on-/off-track alerts.

HOW IT CONNECTS

Read-only links to your work tracker (Jira / GitHub / Linear) and your AI provider's usage & billing API. No agents installed; nothing in any request path.

SECURITY POSTURE — IN PLACE TODAY

SSO (OIDC) + SCIM provisioning	✓
Phishing-resistant MFA (passkeys)	✓
RBAC · audit log → SIEM export	✓
Configurable retention + erasure	✓
Encryption at rest + KMS hook	✓
IR plan · WCAG 2.1 AA · CI security scan	✓

WHY IT'S SAFE FOR MARYLAND HEALTH CONNECTION

Metadata-only · bring-your-own-key · read-only.

Outlay receives token counts, ticket IDs, work types, and dollar figures — **never prompts, model outputs, PHI, PII, or FTI**. None of the data **MARS-E / ARC-AMPE, IRS Pub 1075, or HIPAA** govern ever reaches us, so the integration sits **outside that data scope** — the boundary that stops most vendors.

ON THE ROADMAP — HONEST

SOC 2 Type II	in progress
Annual third-party pen test	scheduled
StateRAMP / GovRAMP	roadmap
FedRAMP cloud + FIPS-validated crypto	deal-gated
The metadata-only architecture keeps most of these out of scope for the data we touch.	

THE PILOT — READ-ONLY, METADATA-ONLY, ZERO DATA-HANDLING RISK

- Scoped to your **development / vendor AI usage** — not any production PHI system.
- Two weeks, free. Nothing for the security review to clear on data flow.
- You get a real **attribution-coverage** number + a **measured forecast accuracy** on your own work.
- We share our SOC 2 timeline & NIST 800-53 control mapping up front.